

Catching Phishing from the Link Alone

A Critical Evaluation of URL-Based Phishing Detection

Gilad Segal

Data Science & Cyber — Dr. Uri Itai · URL / link detector (one half of a two-part project)

Code, data pipeline and reproducible results: github.com/segals/phishing-url-detector

Abstract

Phishing remains a leading initial-access vector, and much of it is carried entirely by a malicious link. This report presents a URL-only phishing detector and subjects it to a critical evaluation rather than treating a high benchmark score as the end of the analysis. Trained on 235,795 real URLs (PhiUSIIL [1]), a tree-ensemble classifier over 40 hand-engineered lexical features reaches $F1 = 0.997$ in-distribution, matching the near-perfect scores reported in the literature. Using single-feature ablation, explainability (SHAP [7]) and a feature-group ablation, we show this score is driven overwhelmingly by a dataset collection artifact — legitimate URLs in this corpus are 100% HTTPS versus 48.6% for phishing — rather than by a transferable phishing signal. An adversarial evaluation shows the detector resists character-level obfuscation (homoglyphs, typosquatting; recall ≥ 0.99) but is evaded completely (recall = 0.00) by hosting phishing content on ordinary HTTPS infrastructure with a clean, short URL. Most critically, evaluated without retraining on an independent 651,191-URL corpus [2], it collapses to $F1 = 0.666$, $AUC = 0.434$ — below 0.5, meaning the ranking is inverted rather than merely uninformative — while a distance-metric analysis (Kolmogorov–Smirnov, Wasserstein) confirms the collapse is driven by exactly the features the model relies on most. On a live feed of current phishing URLs [3], however, recall remains 1.00. We conclude that URL structure alone is not a generalisable phishing signal, and argue for its use as one independent channel within a fused, multi-signal detector.

Contents

1. Introduction	1
2. Background and Related Work	2
3. Data	2
4. Methodology	3
5. Results	4
6. Discussion	11
7. Limitations and Future Work	12
8. Conclusion	12
References	12

1. Introduction

Phishing attacks rely on a victim following a malicious link, so the URL itself is an attractive detection surface: it can be scored in milliseconds, requires no page fetch, preserves user privacy, and can be evaluated before the user clicks. A large body of published work reports near-perfect ($F1 > 0.99$) accuracy on public URL datasets, suggesting the problem is essentially solved. This report interrogates that claim: we reproduce the strong published result, then ask systematically whether it reflects genuine phishing-specific signal or an artifact of how the benchmark was constructed. The investigation is organised around four research questions.

RQ1 (signal). How much of the near-perfect score survives once dataset-specific leakage and collection bias are accounted for? **RQ2 (robustness).** How does the detector respond to an adversary who deliberately reshapes a phishing URL's surface features? **RQ3 (generalisation).** Does the score transfer to an independent dataset and to live phishing traffic? **RQ4 (explainability).** Which features drive the decision, and does that explain the robustness and generalisation results?

This module is one of two independent, complementary detectors built for the course project: this report covers the **URL/link** channel, a companion module the **email content** channel. Both were designed and evaluated independently; fusing them is future work (Section 7). The contribution here is not a new model architecture but an honest, reproducible audit of a standard one.

2. Background and Related Work

Lexical and host-based URL features were established by Ma *et al.* [4], who showed that structural properties of a URL — length, host composition, IP literals, token content — carry substantial discriminative signal without inspecting page content; the feature families in Section 4.1 follow that tradition. Deep character-level models such as URLNet [5] instead learn a representation directly from the URL string, trading interpretability for potential accuracy gains. We deliberately favour interpretable, hand-engineered features: since the central finding of this report is that a near-perfect score is attributable to a specific, nameable artifact, an opaque representation would have obscured precisely the evidence we set out to find.

On the adversarial side, Boucher *et al.* [6] document imperceptible-perturbation attacks against text-processing and web-facing systems, including homoglyph substitution — visually identical characters from other Unicode scripts — motivating both the homoglyph attack and the canonicalisation defence in Section 5.7. For explainability we use SHAP [7], a game-theoretic attribution method that assigns each feature a principled share of a prediction and, unlike a tree model's built-in importance, is defined per-prediction and sums exactly to the model output. Our central concern — that reported accuracy may not transfer across independently collected corpora — is treated as a hypothesis to be tested (Sections 5.9–5.10) rather than assumed.

3. Data

3.1 Primary corpus

The primary dataset is **PhiUSIIL** [1] (UCI Machine Learning Repository, id 967): 235,795 real URLs with a raw URL string, a binary label, and 53 pre-computed features. It is among the largest and most recent public URL datasets and a common benchmark, which motivates its use as the primary object of study. Table 1 summarises the corpus after cleaning; Figure 1 shows the class balance and two representative feature distributions.

dataset	urls	phishing	legitimate	phishing_rate
PhiUSIIL	235370	100520	134850	0.427

Table 1. Composition of the primary PhiUSIIL corpus after cleaning.

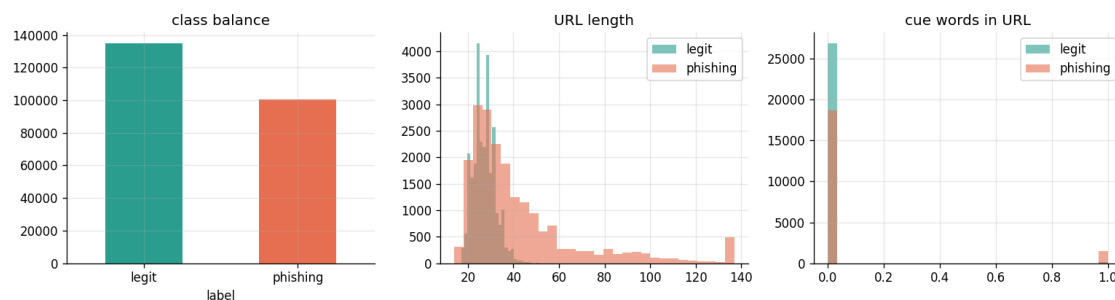


Figure 1. Exploratory view: class balance (left), URL length by class (centre), cue-word count by class (right). The classes separate almost perfectly on trivial structural quantities — an early sign the task is easier than the real-world problem it represents.

3.2 Secondary corpora

Two independent sources support the generalisation analysis. The Kaggle *Malicious URLs* dataset [2] contains 651,191 URLs labelled benign, phishing, defacement or malware; we use the benign/phishing subset, balanced to 40,000 per class. It was collected independently of PhiUSIIL and is itself mixed-class, making it a fair generalisation test rather than a comparison against an unlabelled list. A live snapshot of the **OpenPhish** feed [3] (300 currently active phishing URLs) provides a check against present-day attacks rather than an archived benchmark.

3.3 Data preparation

Preparation was kept deliberately minimal, so the results below are properties of the source data rather than of our preprocessing. Labels were standardised to 1 = phishing (PhiUSIIL uses the opposite polarity); rows with a missing

URL or label were dropped and whitespace stripped. Rows were then **de-duplicated on the exact URL string before splitting** (235,795 → 235,370), so no URL appears in both training and test — a common and easily overlooked source of leakage. No class rebalancing, outlier removal or imputation was performed, and the natural ratio of 42.7% phishing is retained. Feature standardisation is applied only inside the logistic-regression pipeline, where it is required; the tree ensembles consume raw values. The data were split 60/20/20 with a fixed seed (42), stratified on the label; all tuning used the validation partition and the test partition was evaluated once. For reproducibility the cleaned dataset is hashed: rows=235370, phishing_rate=0.4271, sha256=b39e8c2251df... (full value in results/tables/data_hash.txt).

4. Methodology

4.1 Feature engineering

A URL is a short, structured string rather than free prose, so instead of learning a text representation (as a TF-IDF pipeline would for email text) we compute interpretable numeric features directly from the string. All 40 features derive from the URL alone and require no network access, keeping the detector fast, private and reproducible. They fall into six families (Table 2).

family	what it captures	examples
Lexical / length	size and punctuation profile of the string	url_len, n_dots, n_slash, n_digit, digit_ratio
Host / domain	structure of the hostname itself	n_subdomain, is_ip, has_port, core_len
TLD	the suffix and its abuse association	tld_len, suspicious_tld (.tk, .xyz, ...)
Entropy	randomness of the string (generated domains)	url_entropy, host_entropy, core_entropy
Scheme / encoding	transport and character-encoding tricks	is_https, has_punycode, has_hex_encoding, has_at_symbol
Brand / cue	impersonation and social-engineering markers	brand_min_dist, brand_lookalike, n_cue_words, is_shortener

Table 2. The six feature families (40 features), all computed from the URL string alone.

Two families rest on explicit theory. **Entropy** features use the Shannon entropy of a string, $H(s) = -\sum_i p_i \log p_i$, over its character distribution: a predictable string such as *google* scores low, whereas an algorithmically generated domain such as *x7qz9wvt* approaches random noise and scores high — a standard signal for domain-generation algorithms. **Brand** features use the Levenshtein edit distance — the minimum number of single-character insertions, deletions or substitutions transforming one string into another, computed by the standard dynamic-programming recurrence — between each host label and eighteen frequently impersonated brands. A label within edit distance 1–2 of a real brand (e.g. *paypa1* versus *paypal*) is flagged as a probable typosquat.

4.2 Models

Three classifiers were compared and selected on validation F1: **logistic regression** (a linear, directly interpretable baseline with standardised features), **random forest** (trees trained independently on bootstrap samples and averaged), and **histogram-based gradient boosting** (trees fitted sequentially, each correcting its predecessors' residual error, with features bucketed into histograms for speed). The two ensembles represent the two standard strategies — variance reduction by averaging and bias reduction by sequential correction — and neither requires feature scaling.

4.3 Evaluation protocol

Because the majority class accounts for 57.3% of the data, accuracy is not a primary metric: a majority-class classifier attains 57.3% accuracy while catching zero phishing URLs — the *accuracy paradox* (Section 5.1). We report precision, recall, F1, F2, the Matthews Correlation Coefficient (MCC) and AUC-ROC. **F2** weights recall above precision, reflecting that a missed phishing URL costs more than a false alarm. **MCC** uses all four confusion-matrix cells and ranges from −1 to +1 (0 = chance); unlike accuracy or F1 it cannot be inflated by exploiting the majority class, making it the most trustworthy single figure under imbalance. **AUC-ROC** is the probability a randomly drawn phishing URL scores above a randomly drawn legitimate one, so 0.5 is uninformative ranking — and, importantly for Section 5.9, a value below 0.5 indicates a systematically *inverted* ranking rather than absent signal.

Every headline metric carries a **bootstrap 95% confidence interval**: the test set is resampled with replacement 1,000 times, the metric recomputed each time, and the 2.5th and 97.5th percentiles reported. This quantifies how much a metric would vary on comparable data using only the data already collected, preventing over-reading small differences. Paired comparisons additionally use **McNemar's test** on the discordant predictions of two models over the same test

set.

4.4 Threat model and adversarial evaluation

We model a black-box attacker who may freely choose a phishing URL's surface form but must keep it functional — it must still resolve to attacker-controlled content. Four perturbation families are evaluated: *homoglyph substitution* (Latin characters replaced with visually identical Cyrillic or Greek confusables [6]); *typosquatting* (a character duplicated or inserted in the registered domain); *scheme upgrade* (serving the identical page over HTTPS); and *home-page mimicry* (a short, clean, path-free HTTPS domain, approximating the increasingly common abuse of legitimate cloud hosting). Two defences are evaluated: *canonicalisation*, which folds confusable characters to their ASCII skeleton and decodes punycode before scoring, and *de-biasing*, which retrain without the HTTPS feature to test whether the artifact is concentrated in one feature or spread across correlated ones.

4.5 Generalisation and diagnostic tools

Cross-dataset generalisation is measured by training exclusively on PhiUSIIL and evaluating, with no retraining or recalibration, on the independent Kaggle corpus and the live OpenPhish feed. To diagnose *why* a gap occurs we compare per-feature distributions using the **Kolmogorov–Smirnov statistic** (maximum vertical distance between two empirical cumulative distribution functions) and the **Wasserstein** (earth-mover's) distance (minimum probability mass moved, weighted by distance), normalised by the in-distribution standard deviation so features on different scales stay comparable. We additionally report two label-free anomaly detectors trained only on legitimate URLs, and assess calibration via the Brier score and a reliability curve.

5. Results

5.1 Trivial baselines and the accuracy paradox

Table 3 reports three baselines requiring no learning. A majority-class predictor attains 57.3% accuracy with zero recall and MCC exactly 0 — useless for security, yet respectable if judged on accuracy. More revealing, a single rule flagging any non-HTTPS URL as phishing attains $F1 = 0.68$ and $MCC = 0.62$. That a one-line rule captures so much of the task foreshadows Section 5.2. By contrast the cue-word rule — the most intuitively 'phishing-like' heuristic — performs poorly ($F1 = 0.13$).

baseline	accuracy	recall	f1	mcc
majority class (predict legit)	0.573	0.0	0.0	0.0
rule: not https -> phishing	0.793	0.516	0.68	0.616
rule: has cue word -> phishing	0.602	0.072	0.134	0.188

Table 3. Trivial baselines. A single HTTPS check reaches $F1$ 0.68; the intuitive cue-word rule only 0.13.

5.2 Decomposing the near-perfect score

Training on all 50 provided numeric features reproduces the near-perfect literature result ($F1 = 1.000$). Decomposing it is the central diagnostic of this report (Table 4). One provided feature, *URLSimilarityIndex*, attains $F1 = 0.995$ alone. The raw data explains why: it takes the value 100 for **100% of legitimate URLs** while phishing URLs average 49.6 — effectively a re-encoding of the label, and uncomputable at deployment time for a genuinely unseen URL. It is therefore treated as leakage, measured once as evidence and **excluded from every subsequent experiment**; the detector evaluated throughout the rest of this report uses only the 40 features of Section 4.1.

representation	f1	auc	f1_95ci
all 50 provided features (RF)	1.0	1.0	[1.000, 1.000]
single provided feature: URLSimilarityIndex	0.995	0.996	nan
single provided feature: URLCharProb	0.62	0.766	nan
single provided feature: TLDLegitimateProb	0.0	0.607	nan
honest raw-URL lexical (40, RF)	0.997	0.999	[0.996, 0.997]

Table 4. Decomposing the near-perfect score: all provided features, individual provided features, and our leakage-free lexical features. Bootstrap 95% CIs shown where a full model was fitted.

The more interesting result is the last row: our leakage-free features still attain $F1 = 0.997$. This is not leakage but a deeper problem. As Table 5 shows, every legitimate URL in this corpus uses HTTPS while fewer than half the phishing URLs do. This 51-point gap is a property of how the classes were collected — legitimate URLs appear drawn from

clean canonical home-pages, phishing URLs from messy deep links — not of phishing itself. On the contemporary web the association is far weaker, since most phishing sites now serve over HTTPS.

class	https_rate
legitimate	1.0
phishing	0.486

Table 5. HTTPS usage by class in PhiUSIIL: the dominant collection artifact.

5.3 Distribution shape, correlation, and non-parametric testing

URL-derived features are strongly right-skewed and heavy-tailed (Table 6): URL length has skewness 54.7 and excess kurtosis 5,812, indicating a few extremely long URLs far from the bulk of the distribution. Under such distributions the mean and Pearson correlation are unreliable, motivating rank-based statistics and medians throughout.

feature	skewness	excess_kurtosis
url_len	54.65	5811.54
host_len	2.54	10.79
digit_ratio	3.26	12.33
host_entropy	-0.1	0.64
n_cue_words	7.29	66.27
n_subdomain	1.82	7.93

Table 6. Distribution shape of representative features. Large positive skewness and excess kurtosis indicate heavy right tails.

Table 7 compares Pearson (linear) and Spearman (monotone) correlation with the label. They diverge substantially for several features — path length has $r = 0.17$ but $\rho = 0.67$ — confirming strong monotone but non-linear relationships a linear coefficient would understate. The strongest linear relationship is *is_https* ($r = \rho = -0.61$), consistent with Section 5.2. Figure 2 shows the correlation structure among leading features: the path- and length-related features form a strongly inter-correlated block, which matters for interpreting the ablation in Section 5.6.

feature	pearson	spearman
n_slash	0.478	0.671
n_path_segments	0.497	0.671
path_len	0.168	0.669
is_https	-0.613	-0.613
n_digit	0.164	0.542
digit_ratio	0.433	0.538
url_len	0.222	0.38
n_hyphen	0.188	0.368
url_entropy	0.395	0.358
host_hyphen	0.305	0.318

Table 7. Feature–label correlation, Pearson versus Spearman (top 10 by |Spearman|).

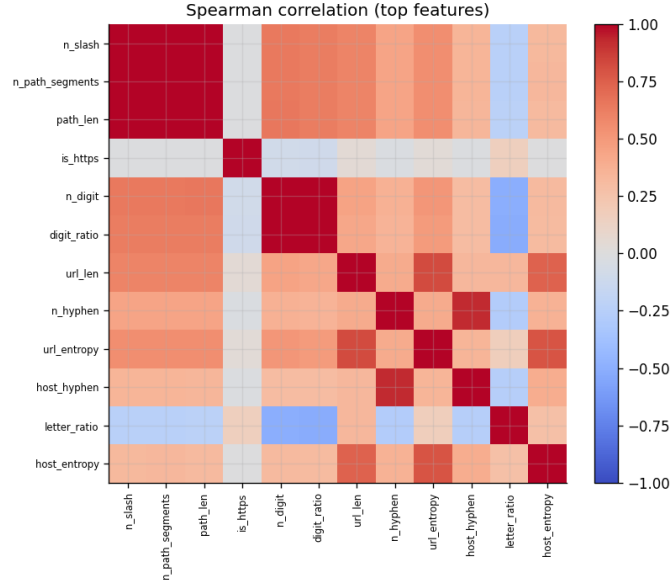


Figure 2. Spearman correlation among leading features. Length- and path-related features form a correlated block, encoding substantially overlapping information.

Because the features are non-normal, class differences are tested with the non-parametric Mann–Whitney U test (Table 8). All features tested differ significantly, with p-values numerically indistinguishable from zero at machine precision — a consequence of the very large sample as much as of effect size. The medians are more informative: phishing URLs are longer (34 vs 27 characters) and marginally higher-entropy, while *is_https* shows complete median separation (0 for phishing, 1 for legitimate), again isolating the artifact.

feature	mannwhitney_p	median_phishing	median_legit
url_len	0.0	34.0	27.0
host_entropy	0.0	3.625	3.424
digit_ratio	0.0	0.0	0.0
n_cue_words	0.0	0.0	0.0
is_https	0.0	0.0	1.0

Table 8. Mann–Whitney U tests of class differences, with class medians.

5.4 Model comparison

Table 9 compares the three classifiers on the 40-feature representation. Random forest and histogram gradient boosting are statistically indistinguishable (McNemar $p = 1.00$, coincident confidence intervals), and both significantly outperform logistic regression ($p = 7.7 \times 10^{-15}$) — statistically real but practically negligible, roughly three F1 thousandths. The intervals are extremely tight (width ≈ 0.001), which matters for this report’s argument: the near-perfect score is stable and reproducible, not an artifact of a fortunate split. The tree ensemble is the reference detector throughout.

model	f1	f1_95ci	recall	precision	mcc	auc	mcnemar_vs_best
logreg	0.994	[0.993, 0.995]	0.99	0.999	0.99	0.998	$p=7.7e-15$
random_forest	0.997	[0.996, 0.997]	0.994	0.999	0.994	0.999	(best)
hist_gbm	0.997	[0.996, 0.997]	0.994	0.999	0.994	0.999	$p=1.0e+00$

Table 9. Model comparison with bootstrap 95% confidence intervals and McNemar tests against the best model.

5.5 Explainability

SHAP attribution [7] (Table 10, Figure 3) identifies *is_https* as dominant, with mean absolute SHAP roughly three times the next-ranked feature. The remaining leaders — path segments, path length, slash count — are structural descriptors of how ‘deep’ a URL is. The explanation converges independently on the conclusion of Section 5.2: the model is largely an HTTPS-and-path-depth detector. Figure 4 cross-checks this with the random forest’s own impurity-based importance, which ranks the same features; agreement between two different attribution methods strengthens the finding.

feature	mean_abs_shap
is_https	0.205
n_path_segments	0.07
path_len	0.062
n_slash	0.05
n_digit	0.025
url_len	0.022
core_len	0.021
digit_ratio	0.02

Table 10. Global SHAP feature importance (top 8 of 40).

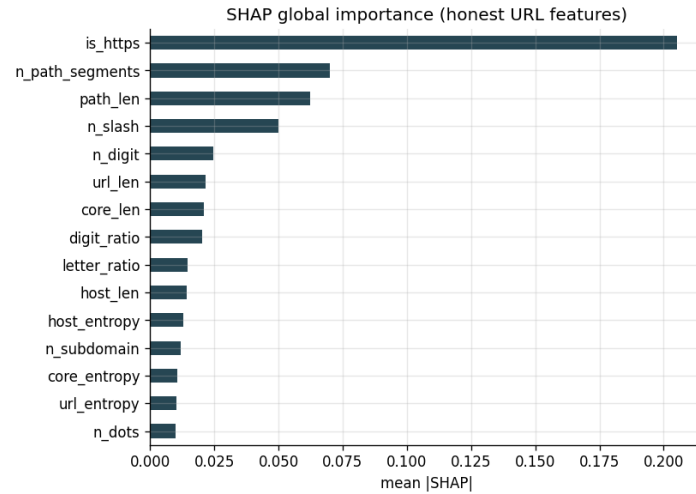


Figure 3. SHAP global feature importance. *is_https* dominates by roughly a factor of three.

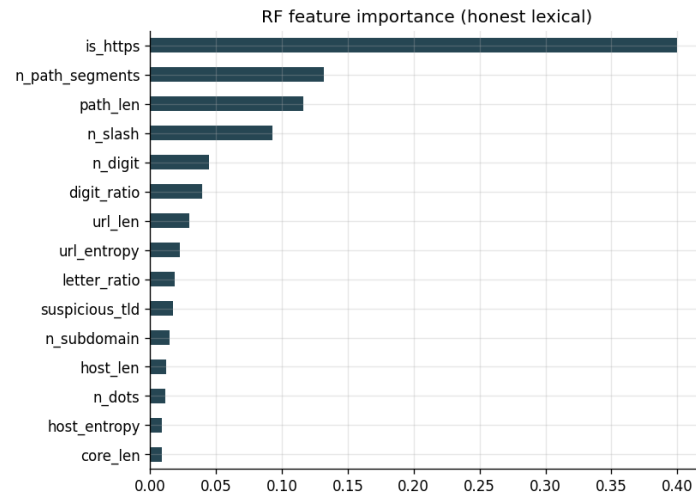


Figure 4. Independent cross-check: the random forest's built-in impurity-based importance, which agrees with the SHAP ranking.

5.6 Feature-group ablation

Training on each of the six families in isolation (Table 11) shows the artifact is not confined to one feature. The *length/counts* family — eight features, none of them *is_https* — reaches $F1 = 0.993$ alone, nearly matching the full model, while the *scheme/encoding* family containing *is_https* reaches only 0.696. The *brand/cue* family, encoding the features most directly associated with phishing intent in prior work [4], is weakest ($F1 = 0.273$). Consistent with the correlation structure in Figure 2, the corpus encodes a broad 'clean home-page versus deep messy link' distinction across many correlated structural proxies, any of which can substitute for the others — anticipating the limited effect of de-biasing in the next section.

feature_group	n_features	f1	auc
length/counts	8	0.993	0.998
host/domain	5	0.687	0.823
tld	2	0.266	0.574
entropy	3	0.806	0.928
scheme/encoding	4	0.696	0.767
brand/cue	5	0.273	0.582

Table 11. Feature-group ablation. Length and count features alone nearly reproduce the full model; brand and cue features contribute least.

5.7 Adversarial robustness

Table 12 and Figure 5 report recall on phishing URLs under each attack and defence. Character-level attacks leave recall essentially unchanged (homoglyph 0.992, typosquat 0.993 against a clean 0.994): a detector built on structural quantities is largely insensitive to which characters appear, in marked contrast to lexical text classifiers, which such attacks defeat [6]. This is a genuine, if incidental, robustness property, complementary to the content-based detector in the companion module.

Along the axis on which the model is biased, however, it is highly vulnerable. A scheme upgrade alone — changing nothing but HTTP to HTTPS — reduces recall from 0.994 to 0.672, so roughly one third of phishing URLs cross the decision boundary from a single free change. Home-page mimicry defeats the detector entirely (recall = 0.000): once a phishing URL is short, path-free and served over HTTPS it matches every structural expectation learned for legitimate traffic. Canonicalisation has no effect on either attack — there is no confusable character to fold — and is effective only against the homoglyph family it targets. Removing *is_https* and retraining recovers only marginally (0.672 → 0.704), confirming the bias is diffuse. No defence within a URL-only feature space closes this gap.

attack	recall_attacked	recall_+normalize	recall_+debias(no https)
(clean)	0.994	0.994	0.994
homoglyph	0.992	0.994	0.994
typosquat	0.993	0.993	0.994
https_upgrade	0.672	0.672	0.704
homepage_mimicry	0.0	0.0	0.0

Table 12. Recall on phishing URLs under each attack, with and without each defence.

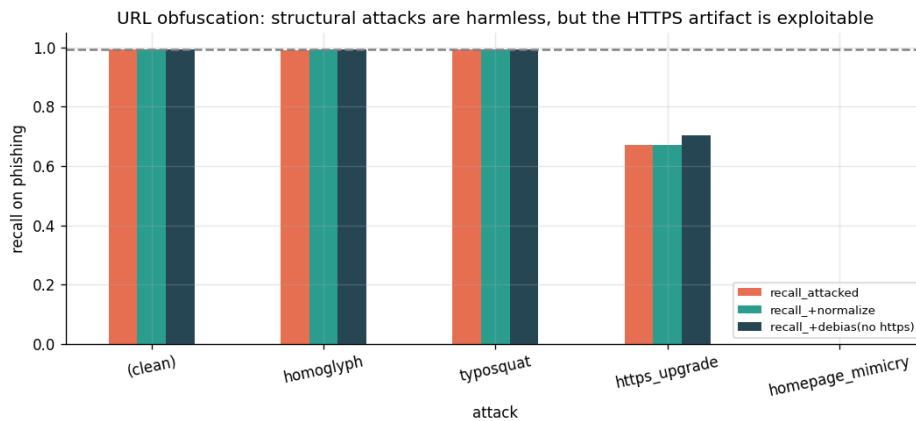


Figure 5. Recall under each attack. Character-level attacks are ineffective; attacks exploiting the HTTPS and path-depth artifact are highly effective.

5.8 Unsupervised detection and calibration

As a weaker-assumption comparison, two unsupervised anomaly detectors were trained exclusively on legitimate URLs, with no phishing labels (Table 13). Isolation Forest, which isolates anomalous points using random splits, attains AUC = 0.828; Local Outlier Factor, comparing a point's local density to its neighbours', attains 0.944. Both are creditable without labelled attack data though below the supervised model, and both depend on the same structural artifacts, since they measure structural unusualness rather than maliciousness.

unsupervised_detector	auc
IsolationForest	0.828
LocalOutlierFactor	0.944

Table 13. Unsupervised anomaly detectors trained only on legitimate URLs.

Calibration was assessed with the Brier score (mean squared error between predicted probability and outcome) and a reliability curve. In-distribution the detector is well calibrated overall (Brier = 0.0025), though Table 14 and Figure 6 show the expected instability in the sparsely populated middle of the range: the model is confidently correct at both extremes, where almost all predictions fall, and noisier between. Section 5.9 shows this calibration does not survive a change of dataset.

mean_predicted	observed_freq
0.003	0.003
0.141	0.293
0.234	0.273
0.34	0.5
0.449	0.25
0.56	0.5
0.634	0.556
0.745	0.364
0.85	0.958
1.0	1.0

Table 14. Reliability table: observed phishing frequency per predicted-probability bin.

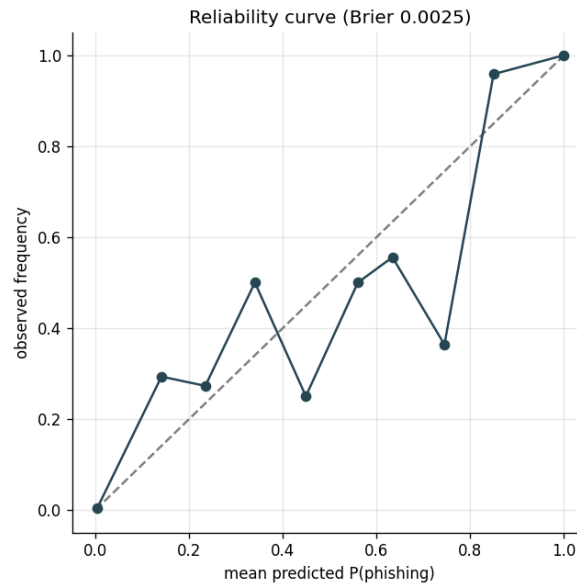


Figure 6. Reliability curve. Points on the diagonal indicate well-calibrated probabilities; the bulk of predictions lie at the two extremes.

5.9 Cross-dataset generalisation

The central generalisation result appears in Table 15 and Figure 7. The in-distribution detector (F1 = 0.997, AUC = 0.999) collapses on the independent Kaggle corpus to F1 = 0.666, AUC = 0.434. Figure 7 makes the mechanism visible: in-distribution the two classes' predicted-probability distributions are cleanly separated (legitimate near 0, phishing near 1); on the independent corpus **both** collapse into the same region near 1.0 (mean predicted probability 1.000 for benign and 0.999 for phishing; 100.0% of benign and 99.9% of phishing scored above 0.9). The model has not merely become less confident — it no longer separates the classes at all.

An AUC below 0.5 reflects this precisely: within that saturated band benign URLs are on average ranked marginally above phishing ones, so the ranking is not merely uninformative but systematically inverted. Hence re-thresholding recovers almost nothing (F1 0.666 → 0.667 at the cost-optimal cut-off): it can repair a model whose ranking is intact but whose operating point is mis-set, not one whose outputs no longer discriminate. Removing *is_https* does not help

either — the de-biased variant is worse ($AUC = 0.168$) — so the failure is not attributable to that single feature. Notably, recall on the **live OpenPhish** feed remains 1.00: present-day phishing URLs are still structurally irregular enough to be caught. The correct reading is that the detector remains useful against today's attacks while being demonstrably non-transferable, and that its high recall on the independent corpus comes with an unacceptable false-positive rate rather than genuine discrimination.

setting	f1	recall_phishing	auc	threshold
in-distribution (PhiUSIIL test)	0.997	0.994	0.999	0.5
cross-dataset (Kaggle, full model)	0.666	0.999	0.434	0.5
cross-dataset (Kaggle, no is_https)	0.666	0.998	0.168	0.5
cross-dataset (Kaggle, re-thresholded)	0.667	1.0	0.434	0.01
live OpenPhish (recall only)	nan	1.0	nan	0.5

Table 15. Cross-dataset generalisation: in-distribution performance versus an independent 651k-URL corpus and a live phishing feed.

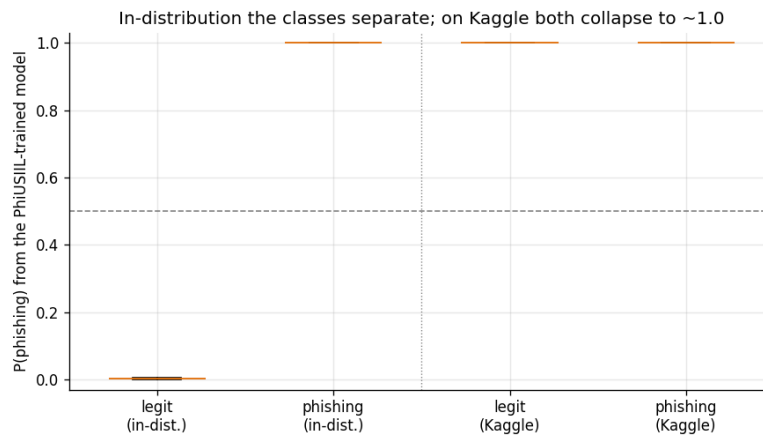


Figure 7. Predicted-probability distributions by true class. In-distribution the classes separate cleanly; on the independent corpus both collapse into the same saturated region.

5.10 Diagnosing the collapse

Table 16 ranks features by distributional distance between the PhiUSIIL and Kaggle distributions. The three most-shifted by Kolmogorov–Smirnov — *is_https* (0.741), *path_len* (0.694) and *n_path_segments* (0.627) — are precisely the features SHAP identified as the strongest decision drivers (Section 5.5); the normalised Wasserstein distances agree. The detector's accuracy is therefore built on the least transferable part of the feature space, a mechanistic explanation of the collapse rather than a restatement of it. Two independent diagnostics — feature attribution and distributional distance — converging on the same small feature set is strong evidence for this causal account.

feature	ks_statistic	wasserstein_norm
is_https	0.741	1.789
path_len	0.694	0.931
n_path_segments	0.627	1.915
n_subdomain	0.435	0.968
url_len	0.343	0.434
n_slash	0.309	1.06
letter_ratio	0.294	0.446
n_dots	0.28	0.559

Table 16. Distributional shift between PhiUSIIL and the independent corpus, by Kolmogorov–Smirnov statistic and normalised Wasserstein distance (top 8 features).

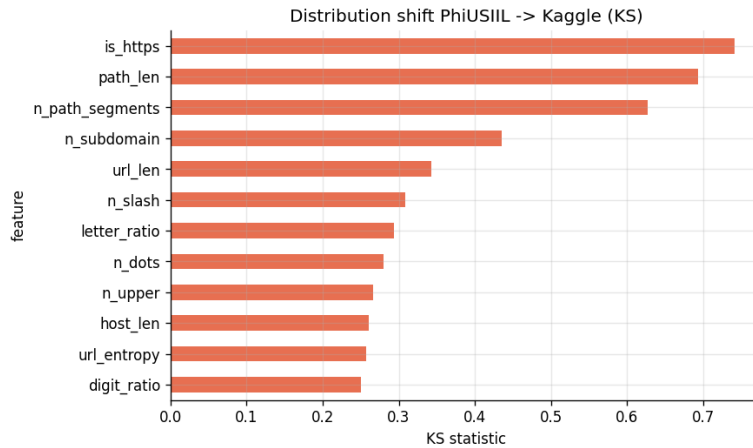


Figure 8. Kolmogorov–Smirnov distance per feature between the two datasets. The most-shifted features coincide with the model’s top SHAP drivers.

5.11 Error analysis

On the clean in-distribution test set of 47,074 URLs the detector makes very few errors: 15 false positives and 119 false negatives (Table 17). Table 18 lists representative examples and is more informative than the counts. False positives are ordinary legitimate sites that look structurally unusual — numeric domains such as *180360.com*, an uncommon TLD in *thefeedbackloop.xyz*, the long multi-label host *provincialarchives.alberta.ca*. The false negatives are more instructive: *what.promerc.repl.co* is phishing hosted on a legitimate developer-sandbox domain — an in-the-wild instance of the home-page-mimicry attack of Section 5.7 — and *microsoft-sicherheitsupdate.com* is a brand-impersonation domain scored at just 0.108 because it is short, HTTPS and structurally clean despite an obvious brand name. The rarity of in-distribution errors, against the severity of the mimicry and cross-dataset failures, shows that clean-data error analysis alone would have missed this report’s central finding.

item	count
false_positive	15
false_negative	119
test_size	47074

Table 17. Error counts on the clean in-distribution test set.

type	URL	y	p
FP	https://www.180360.com	0	0.876
FP	https://www.betterplants.basf.us	0	0.706
FP	https://www.10000birds.com	0	0.561
FP	https://www.thefeedbackloop.xyz	0	0.733
FP	https://www.provincialarchives.alberta.ca	0	0.746
FN	https://what.promerc.repl.co	1	0.011
FN	https://s.smbacmzu.icu	1	0.103
FN	https://www.microsoft-sicherheitsupdate.com	1	0.108
FN	https://www.nailcanhillrun.com.au	1	0.003
FN	https://www.2023foco.com.br	1	0.015

Table 18. Representative errors. The false negatives include phishing on legitimate hosting infrastructure and a structurally clean brand-impersonation domain.

6. Discussion

The four research questions can now be answered. **RQ1 (signal):** very little of the headline score reflects transferable phishing-specific signal — one provided feature is label leakage, and once excluded the remaining score rests on a collection artifact a one-line rule already captures at F1 0.68. **RQ2 (robustness):** the detector genuinely resists cheap character-level evasion, but this is a side-effect of using structural features rather than a designed defence, and it offers no protection against an attacker who simply uses legitimate HTTPS hosting — an attack that reduces recall to zero. **RQ3 (generalisation):** the score does not transfer; on an independent corpus the ranking inverts, a more severe failure

than the miscalibration usually assumed in domain-adaptation settings, and one threshold tuning cannot repair. **RQ4 (explainability):** SHAP and distributional distance independently identify the same features as both the strongest drivers and the least transferable signals, elevating the central claim from observation to causal explanation.

Together these support a methodological conclusion: for URL-based phishing detection, in-distribution benchmark accuracy is close to uninformative about deployment behaviour, so evaluation practice should report cross-dataset performance and adversarial recall as first-class results rather than optional robustness checks. Notably, the companion content-based detector — built on entirely different features and data — reached a structurally similar conclusion: a near-perfect in-distribution text classifier that degraded sharply out-of-distribution and under adversarial perturbation. That two independent signals show the same fragility suggests this is not specific to URL features but a general property of narrow, single-signal phishing classifiers evaluated only in-distribution.

7. Limitations and Future Work

Several limitations bound these conclusions. The cross-dataset comparison is informative but not perfectly controlled: PhiUSIIL and the Kaggle corpus differ in collection methodology as well as in genuine URL characteristics, so part of the measured shift may reflect crawling or encoding conventions. The de-biased variant, which fails even more severely, is partial evidence that the result is not attributable to a single confounding feature, but a fully controlled comparison would need corpora collected under a shared protocol. The feature set is deliberately restricted to string-derived signals and omits network-observable evidence — WHOIS domain age, hosting and certificate reputation, redirect chains — any of which could improve cross-dataset robustness, and precisely because they are harder for an attacker to control they are the most promising extension. The live-feed evaluation uses a single 300-URL snapshot from one provider and is indicative rather than a temporal-drift study. The adversarial evaluation covers four attack families spanning cheap and expensive evasion; it is not exhaustive.

One numerical caveat deserves mention. Because the out-of-distribution scores are saturated — almost every URL in the independent corpus scores above 0.9 (Section 5.9) — the *ordering* within that band is decided by very small differences, so the AUC is correspondingly sensitive: floating-point rounding in the feature values shifts it by a few hundredths (observed range approximately 0.39–0.43 across representations of the same features). The pipeline therefore always consumes the persisted feature artifact, so a run reproduces identically whether or not the cache was present. This does not affect any conclusion: every variant is far below the 0.5 threshold separating a correct ranking from an inverted one, and F1 (0.666) is stable across all of them. It is reported because a metric that moves with numerical noise should be flagged rather than quoted to three decimals as though precise.

The clearest next step follows from Section 5.7: because no defence within the URL-only feature space closes the mimicry gap, the natural remedy is **fusion** with the companion content-based detector, so an attacker who defeats one channel by using legitimate infrastructure must simultaneously defeat an independent second channel reading entirely different evidence.

8. Conclusion

A URL-only phishing detector can be made fast, interpretable and robust to cheap character-level obfuscation, and it still catches a large share of current real-world phishing traffic. However, the near-perfect accuracy such detectors report on standard benchmarks is substantially a property of how those benchmarks were constructed rather than of phishing itself: it is supported in part by outright label leakage, rests otherwise on a collection artifact a single rule can capture, is trivially evaded by an attacker willing to use ordinary legitimate infrastructure, and does not survive contact with an independently collected dataset — where the ranking inverts entirely. URL structure is a useful but insufficient signal on its own, best deployed as one independent component of a fused, multi-signal detection system.

References

- [1] Prasad, A. & Chandra, S. (2024). PhiUSIIL: A diverse security profile empowered phishing URL detection framework based on similarity index and incremental learning. *Computers & Security*, 136, 103545. Dataset: UCI Machine Learning Repository, id 967.
- [2] Siddhartha, M. (2021). *Malicious URLs Dataset* (651,191 URLs). Kaggle.
- [3] OpenPhish. *Community phishing feed*. <https://openphish.com> (snapshot retrieved 2026).

- [4] Ma, J., Saul, L. K., Savage, S., & Voelker, G. M. (2009). Beyond blacklists: learning to detect malicious web sites from suspicious URLs. *Proceedings of the 15th ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, 1245–1254.
- [5] Le, H., Pham, Q., Sahoo, D., & Hoi, S. C. H. (2018). URLNet: learning a URL representation with deep learning for malicious URL detection. *arXiv preprint arXiv:1802.03162*.
- [6] Boucher, N., Shumailov, I., Anderson, R., & Papernot, N. (2022). Bad characters: imperceptible NLP attacks. *2022 IEEE Symposium on Security and Privacy (SP)*, 1987–2004.
- [7] Lundberg, S. M. & Lee, S.-I. (2017). A unified approach to interpreting model predictions. *Advances in Neural Information Processing Systems*, 30, 4765–4774.